

Lab Project:
**Windows System Hardening via Local
Security Policy.**

By: Hadiya Zuberi

1. Lab Task Objectives / Description:

After completing this lab, students will be able to:

1. Analyze default local security settings.
2. Implement advanced password and audit policies.
3. Configure User Rights Assignment for controlled access.
4. Enable and analyze security auditing.
5. Evaluate the impact of misconfigured policies on system security.

2. Software's / Tools Required:

- PC with Windows 11
- Administrator account

3. Lab Procedure & Results:

Scenario

You are appointed as a System Security Administrator in a university computer lab. Recently, multiple unauthorized login attempts were detected. You are required to harden the system using Local Security Policy.

Task 1 Baseline Analysis (Pre-Configuration)

STEPS:

1. Open Run → secpol.msc
2. Review:
 - Password Policy
 - Account Lockout Policy
 - Audit Policy
 - User Rights Assignment

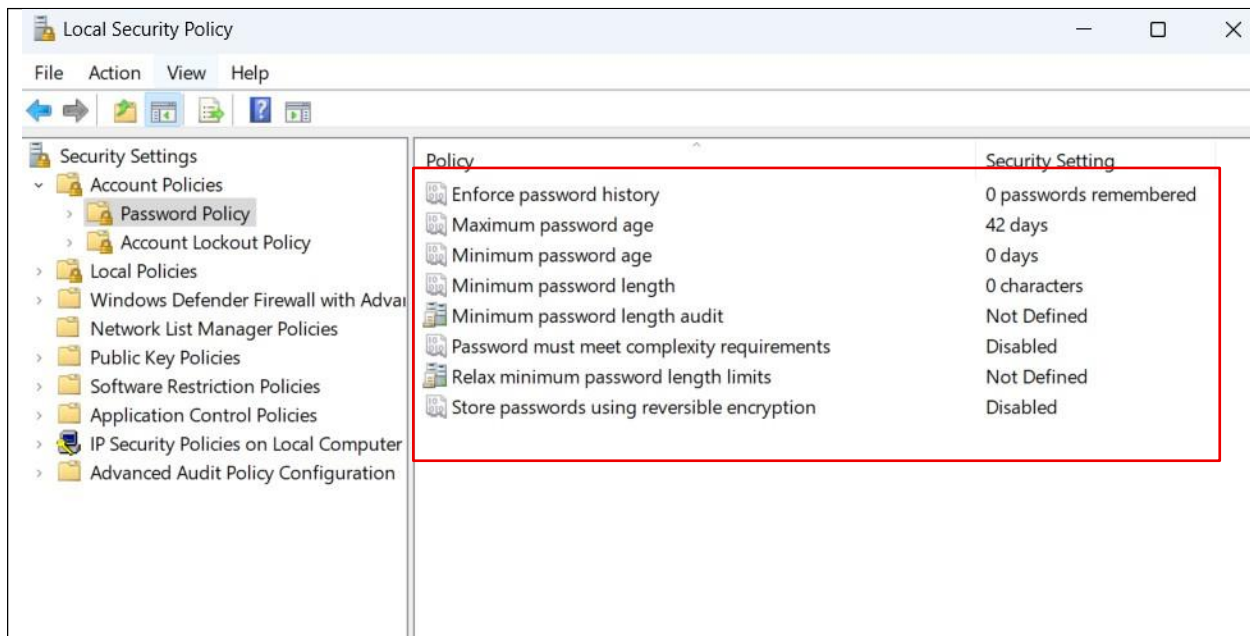


Figure 1.1 Baseline analysis

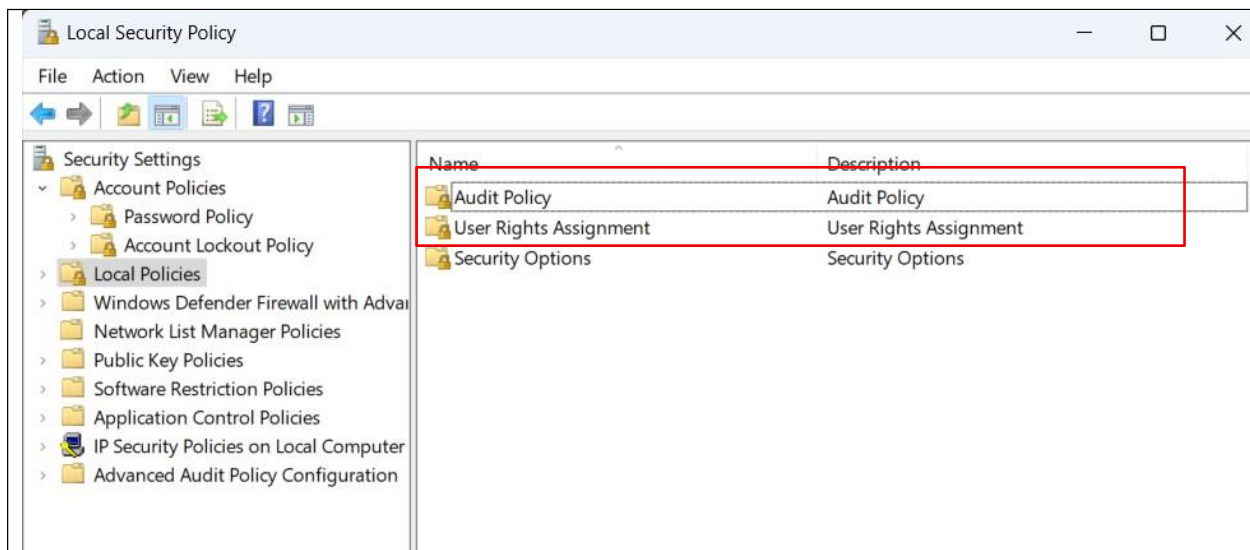


Figure 1.2 Baseline analysis

Task 2 Implement Advanced Password Policy

STEPS:

Navigate to:

Security Settings → Account Policies → Password Policy

Configure:

- Minimum password length → 10 characters
- Enforce password history → 5 passwords
- Maximum password age → 45 days
- Password must meet complexity requirements → Enabled
- Store passwords using reversible encryption → Disabled

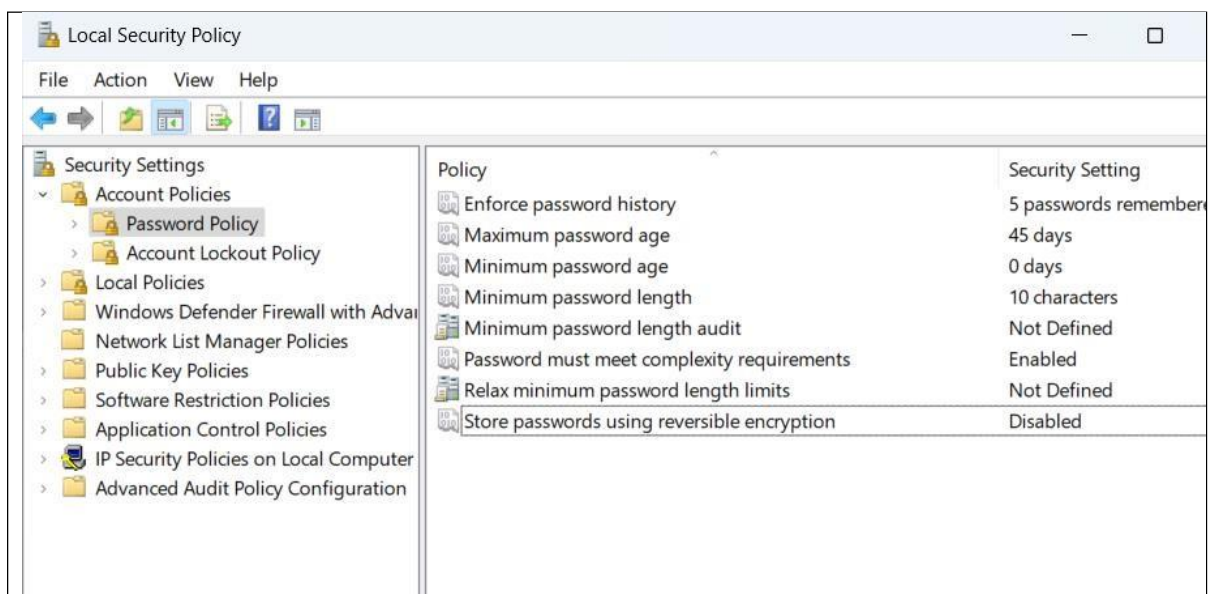


Figure 2.1 After implementation of configurations

Task 3 Advanced Account Lockout Configuration

STEPS:

Navigate to:

Account Lockout Policy

Set:

- Lockout threshold → 3 attempts
- Lockout duration → 20 minutes
- Reset counter after → 15 minutes

Test using incorrect login attempts.

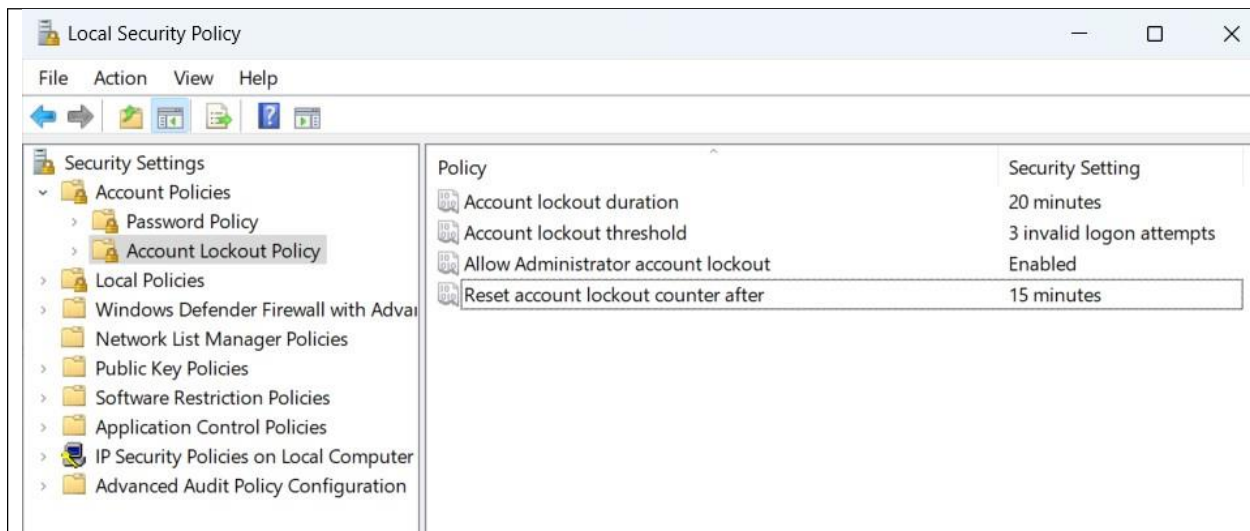


Figure 3.1 Advanced Account lockout configuration

Task 4 Enable Audit Policies:

STEPS:

Navigate to:

Security Settings → Local Policies → Audit Policy

Enable:

- Audit logon events (Success & Failure)
- Audit account logon events
- Audit object access
- Audit policy change
- Audit privilege use

After enabling:

1. Attempt successful and failed logins.
2. Open Event Viewer (eventvwr.msc)
3. Go to:

Windows Logs → Security

Identify Event IDs for:

- Successful login
- Failed login
- Account logout

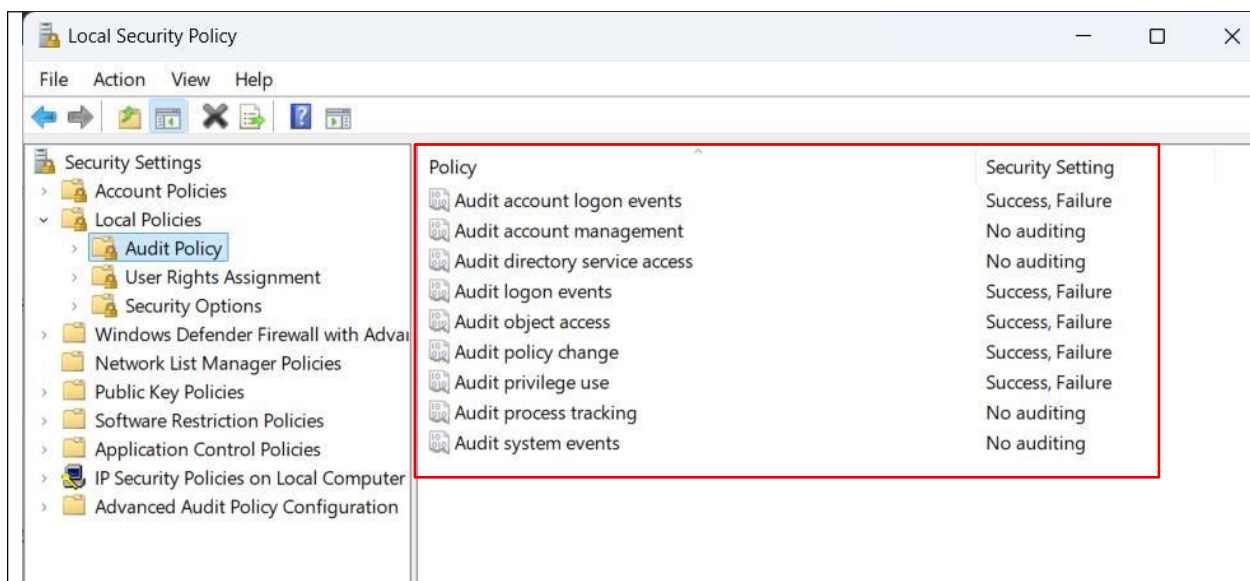


Figure 4.1 Enabling Audit Policies

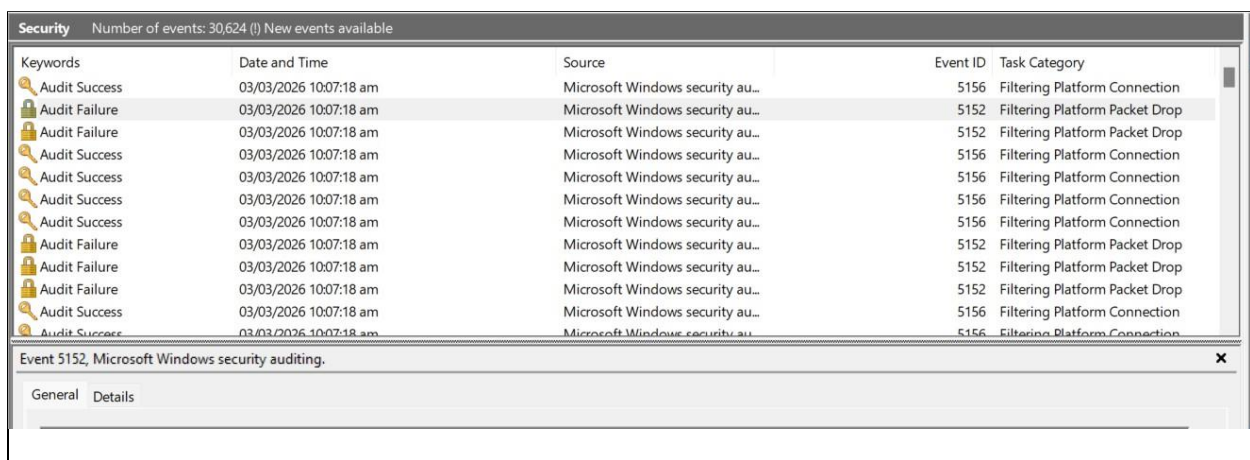


Figure 4.2 Checking logs after attempts of logging

Task 5 User Rights Hardening:

STEPS:

Navigate to:

Local Policies → User Rights Assignment

Perform:

1. Remove "Users" group from:

- Shut down the system

2. Add test user to:

- Deny log on locally

3. Restrict access to:

- Access this computer from the network (allow only Administrator)

Test each configuration.

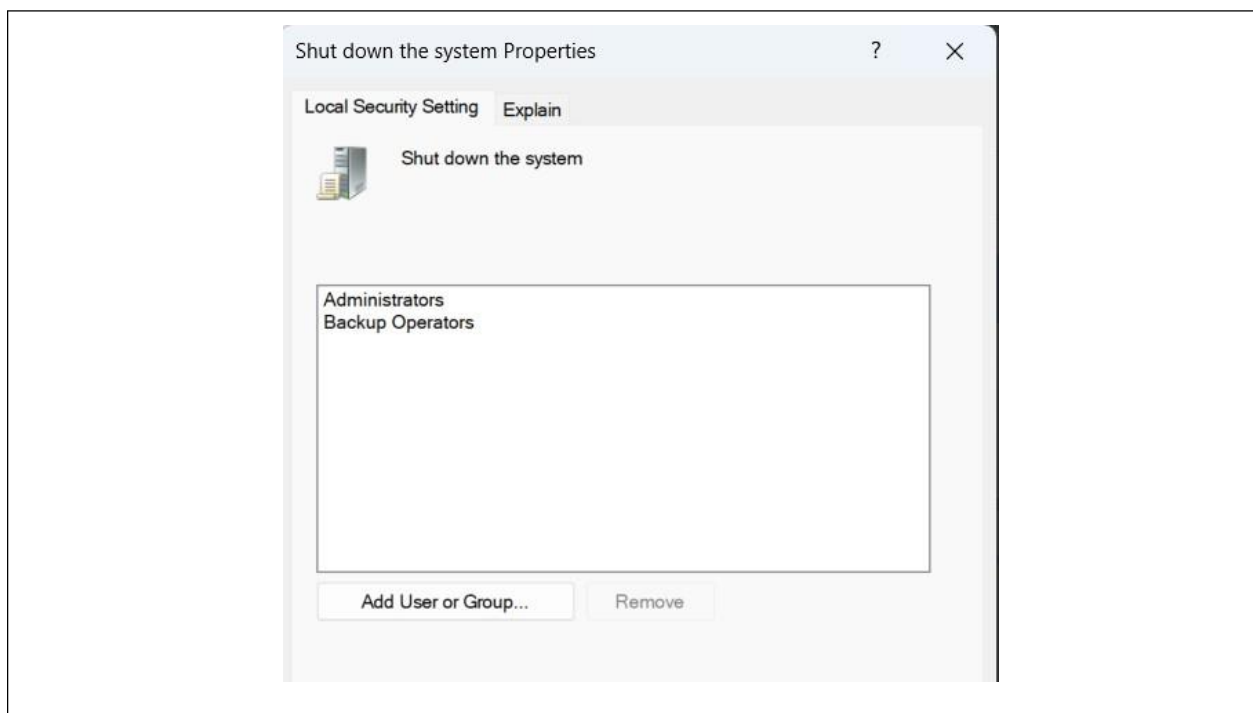


Figure 5.1 Remove "Users" group from shut down the system

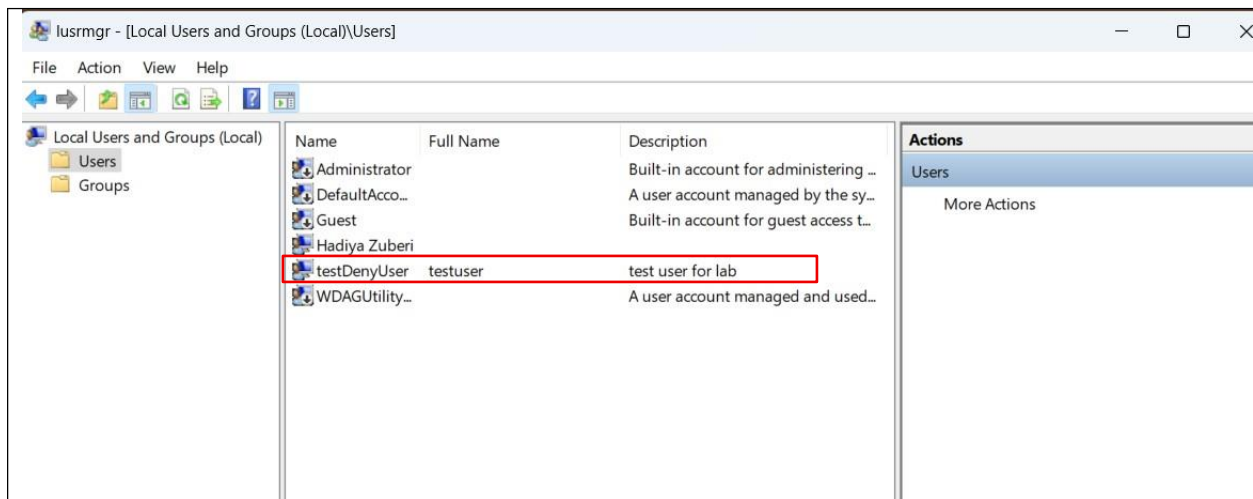


Figure 5.2 Adding another user account for adding another test user

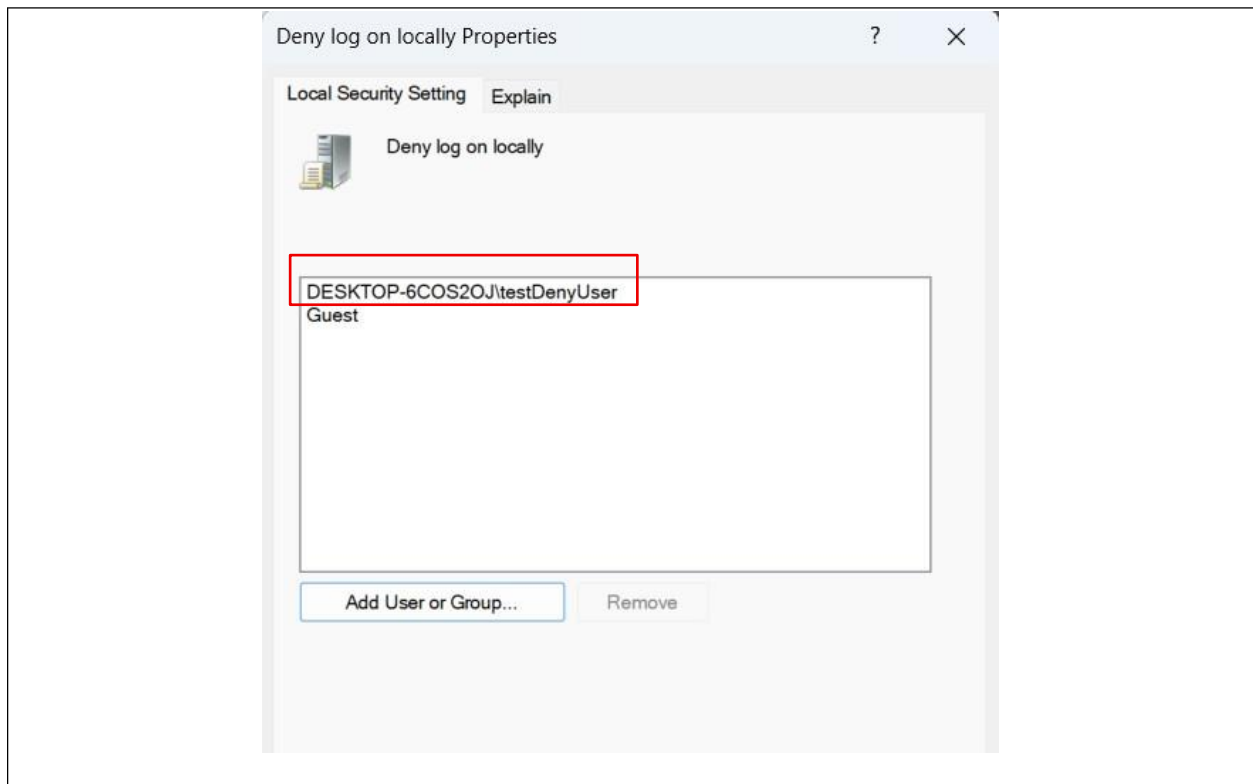


Figure 5.3 Add the created test user to Deny log on locally

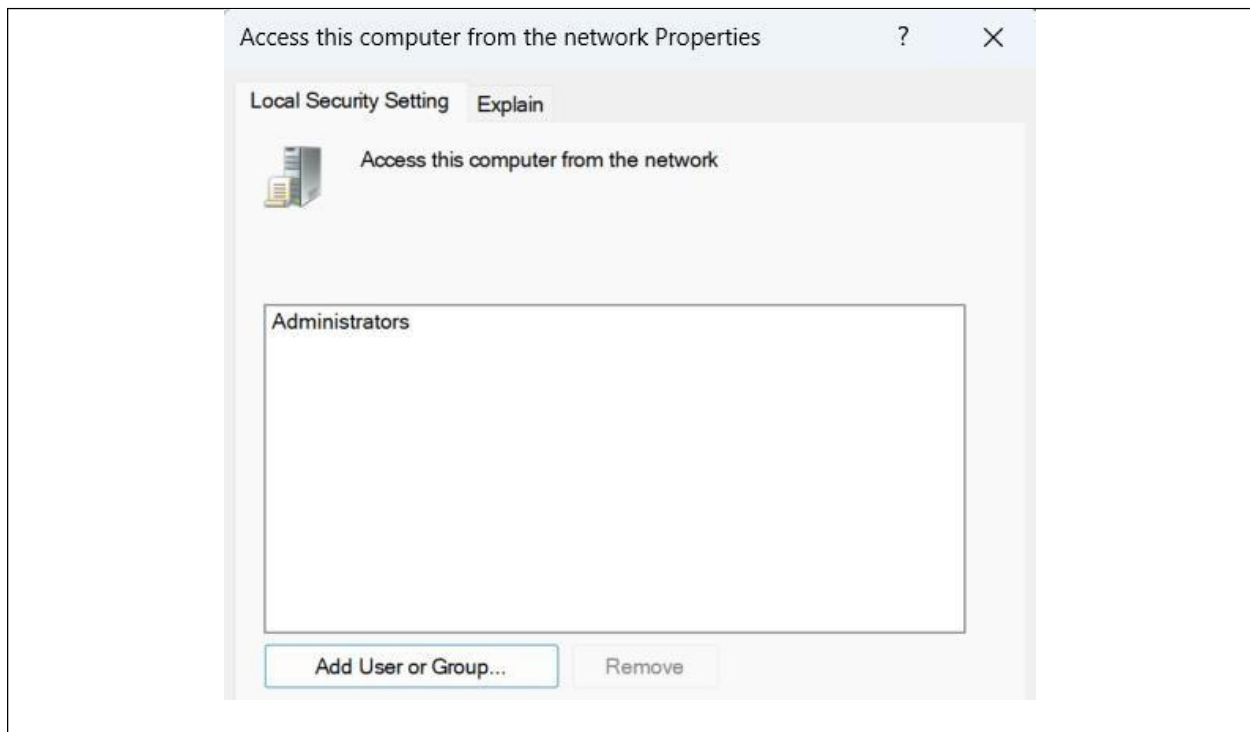


Figure 5.3 Let only administrator remain on access this computer from the network

Task 6 Security Options Hardening:

STEPS:

Navigate to:

Security Settings → Local Policies → Security Options

Configure:

- Accounts: Rename administrator account
- Accounts: Rename guest account
- Interactive logon: Do not display last username → Enabled
- Microsoft network client: Digitally sign communications → Enabled

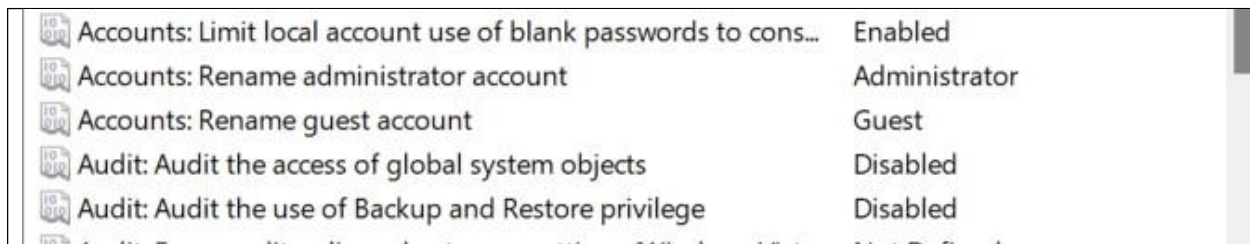


Figure 6.1 Rename Administrator and Guest accounts

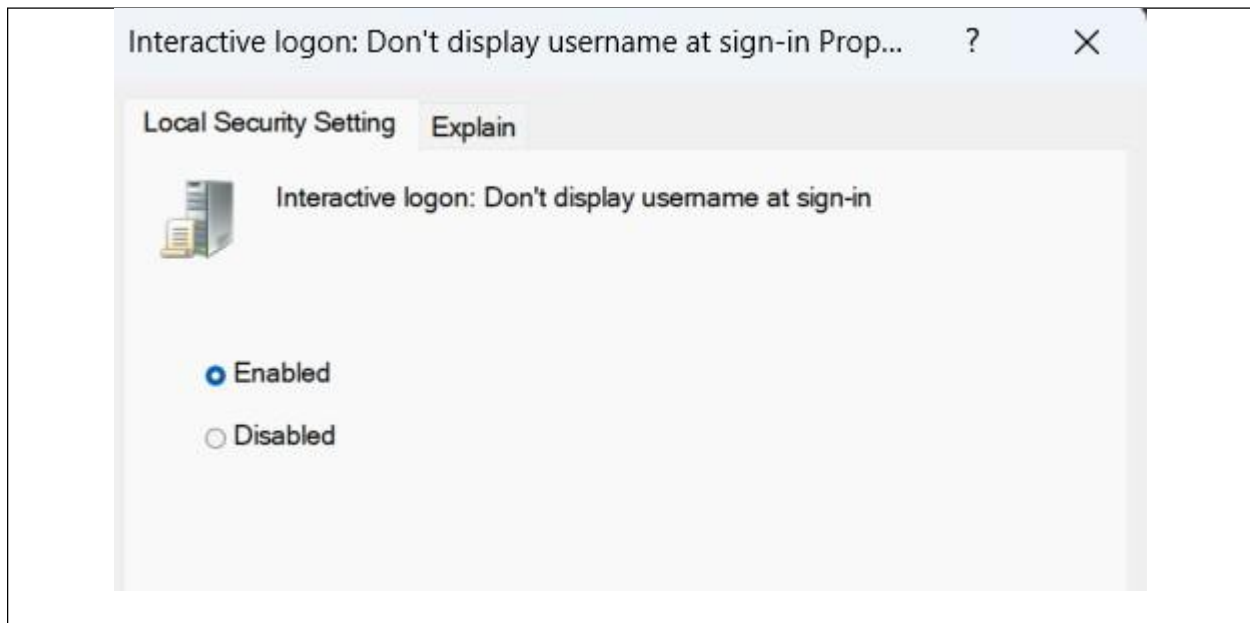


Figure 6.2 Enable Don't display user name at sign-in

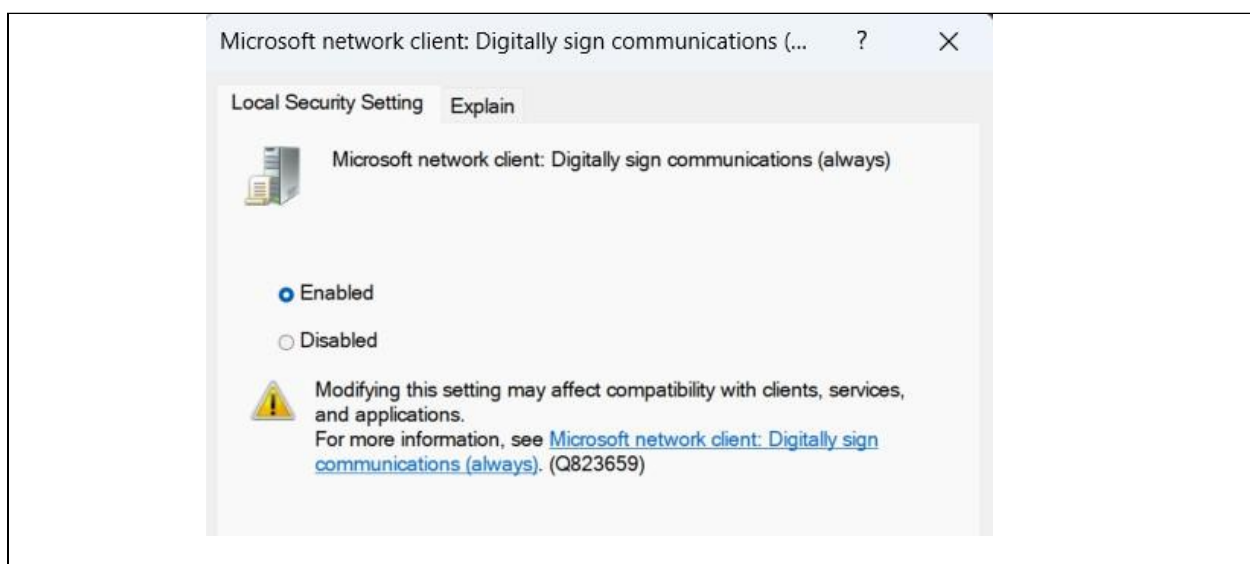


Figure 6.3 Enable digitally sign communications

Task 7 Design a Secure Local Policy configuration for:

STEPS:

- A banking workstation
- A university lab computer
- A home user PC

Banking Workstation:**1. Account Policies****Password Policy**

- Minimum length: 14–16
- Complexity: Enabled
- History: 10–24
- Max age: 60 days

Account Lockout

- Threshold: 3 attempts
- Lockout duration: 30 minutes
- Reset counter: 30 minutes

Reason: Prevent brute-force & shoulder-surfing follow-up attempts.

2. User Rights Assignment

Deny log on locally:

- Guest
- All service accounts
- Backup operators (unless required)

Deny log on through Remote Desktop:

- All non-admin users

Allow log on locally:

- Only authorized employee accounts

3. Security Options

- Rename Administrator account
- Disable Guest account
- Disable storing LM hashes
- Interactive logon: Do not display last username
- Require CTRL+ALT+DEL

4. Device Control (Local Policy)

- Disable removable storage
- Disable autorun
- Prevent installation of unsigned drivers

5. Audit Policy (Basic)

Enable auditing for:

- Logon events
- Account lockout
- Privilege use
- Object access

University Lab computer:

1. Account Policies

Password Policy:

- Minimum length: 10–12
- Complexity: Enabled
- History: 5
- Max age: 90 days

Account Lockout:

- Threshold: 5 attempts
- Lockout duration: 15 minutes

Reason: Avoid frequent student lockouts.

2. User Rights Assignment

Deny log on locally:

- Guest
- Service accounts

Deny log on through Remote Desktop:

- Students

Allow log on locally:

- Students group
- Lab administrators

3. Security Controls

- Disable control panel access (students)
- Prevent software installation
- Block command prompt (optional)
- Enable mandatory user profiles (if possible)

4. Device Control

- USB: Read-only OR monitored
- Disable boot from USB (BIOS level)

5. Audit Policy

Audit:

- Logon events
- Object access
- Policy changes

Home User PC:**1. Account Policies****Password Policy:**

- Minimum length: 10–12
- Complexity: Enabled
- History: 3
- Max age: 180 days

Account Lockout:

- Threshold: 5–10 attempts
- Lockout duration: 10 minutes

Reason: Prevent brute force but avoid self-lockout.

2. User Rights Assignment

Deny log on locally:

- Guest
- Test accounts

Allow log on locally:

- Primary user

Remote Desktop:

- Disabled unless needed

3. Security Options

- Disable Guest account
- Enable SmartScreen
- Require UAC at highest level
- Enable Windows Defender

4. Device Control

USB: Allowed

Autorun: Disabled

Task 8: Answer the following questions

1. Why is reversible encryption dangerous?

Reversible encryption is dangerous because it allows stored passwords to be decrypted back into their original plaintext form. This means that if an attacker gains access to the system and obtains the decryption key, they can recover all user passwords. It is essentially similar to storing passwords in plain text, which significantly increases security risks. If users reuse their passwords on other systems such as email or banking platforms, a breach can lead to further compromises. Secure systems should store passwords using one way hashing algorithms, which cannot be reversed, ensuring that even administrators cannot retrieve the original password.

2. Explain how audit logs help in digital forensics.

Audit logs play a critical role in digital forensics because they record system activities such as login attempts, file access, privilege changes, and policy modifications. During an investigation, these logs help reconstruct the timeline of an attack by showing who accessed the system, at what time, and what actions were performed. They assist investigators in identifying unauthorized access attempts, tracing privilege escalation, and detecting suspicious behavior. Audit logs also serve as legal evidence in court and are essential for regulatory compliance, especially in sectors like banking and education. Without proper logging, it becomes extremely difficult to determine what happened after a security incident.

3. Why is renaming the Administrator account considered a security practice?

Renaming the default Administrator account is considered a security practice because attackers commonly target accounts with known default usernames. Since the "Administrator" account exists on all Windows systems, it becomes a primary target for brute-force and automated attacks. By renaming this account, administrators make it more difficult for attackers to guess valid credentials, as they must first determine the correct username before attempting password attacks. Although this does not fully secure the account on its own, it adds an additional layer of defense and should be combined with strong passwords and proper account lockout policies.

4. Suggest three additional hardening steps outside Local Security Policy.

Three additional hardening steps outside Local Security Policy include enabling full disk encryption, disabling unnecessary services, and implementing application control. Enabling disk encryption such as BitLocker protects data if the device is stolen by preventing unauthorized offline access to files. Disabling unnecessary services reduces the system's attack surface by eliminating potential entry points for attackers. Implementing application control mechanisms, such as AppLocker or similar tools, ensures that only approved software can run on the system, reducing the risk of malware execution. These measures strengthen overall system security beyond basic policy configuration.

5. Explain how account lockout policy can cause Denial of Service (DoS).

An account lockout policy can cause a Denial of Service if it is configured with a very low threshold for failed login attempts. For example, if an account locks after three incorrect attempts, an attacker can intentionally enter the wrong password multiple times to lock the account. This prevents legitimate users from accessing the system, effectively disrupting normal operations. In environments such as banks or universities, repeated lockouts could interfere with business activities or academic work. Therefore, while account lockout policies protect against brute-force attacks, they must be carefully configured to avoid creating opportunities for service disruption.